EM CONSULTING BÉNIN

Conseil · Formation · Cybersécurité

CAHIER DES CHARGES

EM AUTH

Plateforme d'authentification et de gestion des accès

Version 3.0 · 1er novembre 2026

INFORMATIONS GÉNÉRALES

VERSION / DATE	3.0 — 1er novembre 2026
DOMAINE	Authentification et gestion des accès
PREMIÈRE CIBLE	Une organisation et une application web interne intégrable
RÉDIGÉ PAR	**ANIAMBOSSOU Stane**
DESTINATAIRE	M. EDOH Agnitè Maxim W. S. — Directeur, EM Consulting Bénin

Sommaire

1. Présentation générale du projet 2
2. Contexte et problématique 3
3. Objectifs du projet 3
4. Présentation de la solution envisagée 4
5. Périmètre fonctionnel et exigences 5
6. Outils techniques 8
7. Architecture et fonctionnement général 9
8. Méthodologie de réalisation 9
9. Sécurité, données et conformité 10
10. Planning d'exécution 10
11. Critères de réussite et d'évaluation 12
12. Conclusion 13
Annexe A — Glossaire 13
Annexe B — Références 14

Cliquer sur une entrée pour accéder directement à la section correspondante.

1. Présentation générale du projet

1.1 Intitulé et organisation concernée

Intitulé du projet	**EM AUTH** — plateforme d'authentification et de gestion des accès
Organisation concernée	EM Consulting Bénin, cabinet de conseil et de formation professionnelle établi à Haie-Vive (Cotonou), dont les activités couvrent notamment la formation informatique, le conseil et la cybersécurité
Domaine	Identité numérique et sécurité des accès aux applications
Nature du projet	Conception et réalisation d'une plateforme d'authentification intégrable, accompagnée de services d'intégration et d'assistance
Rédaction	ANIAMBOSSOU Stane — version 3.0, 1er novembre 2026

1.2 Origine et finalité

EM AUTH est un projet conçu pour répondre à un besoin devenu central : protéger l'accès aux applications et aux ressources sensibles des organisations, tout en restant utilisable, intégrable et maîtrisable en coût. Il a été soumis par la direction d'EM Consulting Bénin comme projet de conception et de réalisation.

Sa finalité est de fournir un accès robuste et accessible à des applications de criticité variable — finances, administration, ERP, messagerie, ressources humaines, portails, éducation — sans se substituer aux autorisations métier de ces applications, à leurs sauvegardes ni au chiffrement de leurs données. À terme, la vision est celle d'une offre de confiance numérique conçue au Bénin et extensible progressivement.

Le présent cahier des charges expose le résultat du travail de recherche et de conception conduit à ce stade : analyse des mécanismes d'authentification, des protocoles de fédération, des recommandations de sécurité, des outils open source disponibles et de leur adéquation aux ressources locales.

2. Contexte et problématique

2.1 Enjeux de l'authentification

La plupart des incidents de sécurité applicative passent par l'identité : mots de passe volés ou devinés, hameçonnage, interception de session, récupération de compte frauduleuse, droits excessifs ou non retirés au départ d'un utilisateur. Les recommandations actuelles, notamment le référentiel NIST SP 800-63B-4 et les bonnes pratiques OAuth de la RFC 9700, privilégient des facteurs résistants au phishing, des protocoles de fédération maîtrisés et un contrôle strict du cycle de vie des accès.

Pour une organisation, déployer ces mécanismes n'est pas trivial : il faut gérer l'enrôlement des utilisateurs, la récupération en cas de perte, la révocation effective des accès sur chaque application, l'exploitation et le support, le tout avec des compétences et un budget limités.

2.2 Constats généraux et contraintes de conception

- Les applications à protéger sont hétérogènes (anciennes ou récentes, internes ou exposées) et ne gèrent pas toutes l'authentification de la même manière.
- La diversité des appareils, des compétences numériques et des conditions de connectivité, ainsi que l'usage possible de postes partagés, imposent une expérience accessible et en français.
- La maîtrise des coûts conduit à privilégier des composants open source éprouvés et un déploiement progressif.
- Un accès sécurisé n'a de valeur que si le retrait des droits est effectivement observé sur toutes les applications concernées.

Ces constats sont issus des recherches menées ; ils ne décrivent pas des difficultés internes propres à un client particulier, dont l'examen relèvera de l'étape de qualification de chaque application.

2.3 Problématique

> **Problématique**
> Comment fournir un accès robuste, utilisable et intégrable à des applications de criticité différente, tout en maîtrisant l'enrôlement, la récupération, le retrait des accès, l'exploitation et les coûts ?

3. Objectifs du projet

3.1 Objectif général

Concevoir et réaliser une plateforme d'authentification et de gestion des accès qui sécurise l'accès à une application web interne intégrable, de la qualification de l'application à l'exploitation et à la réversibilité, en commençant par un banc de démonstration sur données fictives.

3.2 Objectifs spécifiques

1. **Qualifier** une application, ses chemins d'accès et ses propriétaires avant de la déclarer protégée.
2. **Authentifier selon le risque** : authentification proportionnée pour les utilisateurs ordinaires, MFA résistante au phishing pour les privilèges et les actions sensibles.
3. **Enrôler et récupérer** de façon contrôlée : identité non ambiguë, invitation à usage unique, récupération avec preuve indépendante et double contrôle.
4. **Encadrer les sessions et les privilèges**, et assurer un retrait effectif et mesuré des accès sur chaque cible.
5. **Intégrer** l'application selon un profil standard (OpenID Connect, Code + PKCE) sans accès direct non maîtrisé.
6. **Garantir l'exploitation** : journaux minimisés, supervision, sauvegardes, restauration, support et sortie.
7. **Offrir une expérience accessible** en français, conforme aux principes WCAG 2.2.
8. **Mesurer** la valeur, les risques et le coût complet avant toute généralisation.

3.3 Résultats attendus

Nature	Résultats
Fonctionnels	Parcours complet qualifier → enrôler → accéder → récupérer → retirer → exploiter, démontré sur une application intégrée
Techniques	Plateforme déployable (Keycloak, PostgreSQL, interface et BFF), intégration OIDC, sauvegardes restaurées, suite de tests exécutée
Organisationnels	Dossier d'intégration, dossier d'exploitation, bilan chiffré (heures, coûts, incidents)

4. Présentation de la solution envisagée

4.1 Principe de fonctionnement

EM AUTH repose sur un fournisseur d'identité central (Keycloak) auquel les applications déléguent l'authentification selon le protocole OpenID Connect. Une interface web et un serveur intermédiaire (BFF) conduisent l'utilisateur dans ses parcours, tandis que l'application métier conserve la responsabilité de ses droits et vérifie chaque requête côté ressource.

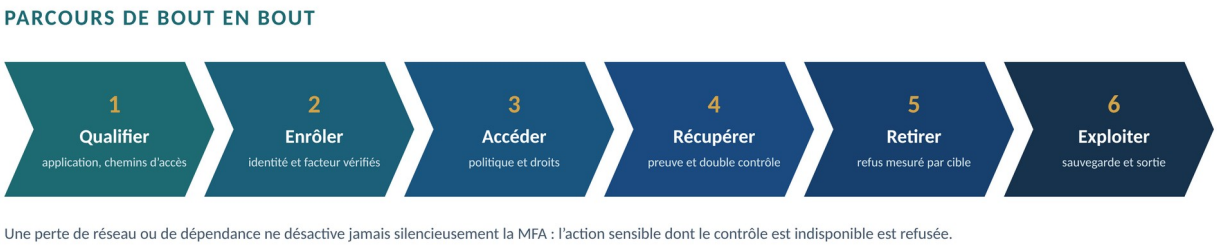


Figure 1 — Parcours de bout en bout

4.2 Parcours utilisateurs

Étape	Description
1. Qualifier	Identifier le propriétaire, l'application, ses interfaces, API et accès directs, et son niveau de risque ; un chemin non maîtrisé exclut toute promesse de protection
2. Enrôler	Sur mandat, vérifier l'identité et le destinataire, puis enregistrer un facteur ; refuser les invitations expirées ou rejouées
3. Accéder	Authentifier selon la politique, contrôler les droits côté ressource et exiger une preuve forte et fraîche pour l'action sensible
4. Récupérer	Vérifier indépendamment, faire approuver par une seconde personne, retirer le facteur perdu et notifier
5. Retirer	Empêcher les nouvelles connexions, traiter sessions et droits, puis mesurer le refus sur chaque cible
6. Exploiter et sortir	Superviser, sauvegarder, restaurer et réconcilier les retraits ; exporter sous mandat et réenrôler les facteurs non transférables

4.3 Mécanismes de sécurité essentiels

- **MFA résistante au phishing** (WebAuthn) pour les privilèges et actions sensibles, sans dégradation silencieuse vers un code à usage unique ou un SMS.
- **Récupération sensible** avec preuve indépendante et double contrôle avant tout nouvel authentificateur.
- **Sessions** contrôlées côté serveur, cookies protégés, défense CSRF, rotation de l'identifiant à l'authentification.
- **Jetons** validés (émetteur, audience, signature, état, nonce), conservés côté serveur par le BFF.
- **Retrait effectif** : refus observé par cible ; une cible non observée est signalée comme inconnue, jamais comme réussie.
- **Panne** : si le contrôle est indisponible, l'action sensible est refusée ; la MFA n'est jamais désactivée globalement.

4.4 Limites fonctionnelles

- EM AUTH ne remplace ni l'annuaire de l'organisation, ni les autorisations métier des applications.
- Aucun fonctionnement hors ligne, aucune disponibilité continue ni absence de compromission ne sont garantis.
- SAML, SCIM, facturation automatisée et intégrations universelles ne font pas partie de la première tranche.
- La première tranche est centrée sur une organisation et une application ; le multi-organisation fera l'objet d'une étude et de tests ultérieurs.

5. Périmètre fonctionnel et exigences

5.1 Première tranche

Dans la première tranche	Hors de la première tranche
Une organisation et une application web interne intégrable ; banc synthétique d'abord	Multi-organisation, SaaS multitenant, haute disponibilité
Gestion des identités et facteurs, authentification, sessions, retrait, administration minimale	Remplacement général des annuaires ou des autorisations métier

Dans la première tranche	Hors de la première tranche
Intégration accompagnée, journaux minimisés, support, sauvegardes et reprise	SAML, SCIM, facturation automatisée
Protection des actions sensibles et assistance accessible	Accès hors ligne ou disponibilité continue

5.2 Modules et exigences

Les besoins sont organisés en treize modules (M01 à M13) et 36 exigences (REQ-13-01 à REQ-13-36), chacune associée à un scénario de vérification (T13-xx) exécutable. Les tableaux suivants reprennent l'essentiel.

Identité, mandat et enrôlement

Exigence	Comportement attendu	Vérification
REQ-13-01 · M01 Qualification du périmètre	Inventorier points d'accès, propriétaires et responsabilités avant activation ; un chemin direct non maîtrisé interdit de déclarer la cible protégée	Comparer inventaire, routes et essais de contournement
REQ-13-02 · M01 Mandat et approbation	Toute action de gestion d'accès est demandée et approuvée par les rôles mandatés ; sans mandat, refus ou mise en attente	Demandes valides, absentes et hors rôle
REQ-13-03 · M02 Identité non ambiguë	Rapprocher une identité par identifiant stable et preuve adaptée ; correspondance ambiguë ou fondée sur l'e-mail seul : suspendre et escalader	Deux identités fictives partageant une adresse
REQ-13-04 · M02 Enrôlement contrôlé	Activer compte et facteur après autorisation et vérification du destinataire ; invitation expirée, rejouée ou non autorisée : aucune activation	Invitation valide, expirée, rejouée, destinataire erroné

Authentification et récupération

Exigence	Comportement attendu	Vérification
REQ-13-05 · M03 Privilèges protégés	MFA résistante au phishing pour privilèges et actions sensibles ; OTP simple ou facteur absent : refus	Preuve forte puis OTP seul
REQ-13-06 · M03 Authentification ordinaire proportionnée	Politique selon la criticité et les appareils ; politique inconnue : pas d'accès au-delà de ce qui est vérifié	Profils, refus, preuves disponibles
REQ-13-07 · M03 Essais massifs	Limiter et surveiller les tentatives (guessing, password spraying) sans révéler l'existence d'un compte	Essais répartis sur données fictives
REQ-13-08 · M04 Récupération vérifiée	Preuve indépendante et double contrôle avant tout nouvel authentificateur	Perte légitime, usurpation, double contrôle manquant
REQ-13-09 · M04 Perte et notification	Retirer le facteur perdu et notifier par canal adapté ; notification impossible : tracer et escalader	Perte, notification échouée, réutilisation
REQ-13-10 · M04 Accès d'urgence	Accès d'urgence séparé, fortement authentifié, surveillé et indépendant de la dépendance couverte	Panne ciblée, usage autorisé et non autorisé

Retrait, droits et administration

Exigence	Comportement attendu	Vérification
REQ-13-11 · M05 Suspension	Empêcher toute nouvelle authentification du compte ciblé	Désactiver un compte fictif, retenter depuis un navigateur neuf
REQ-13-12 · M05 Retrait multi-cibles	Révoquer ou invalider les accès sur toutes les cibles incluses, puis confirmer le refus ; cible non observée : INCONNU	Mesure de l'ordre autorisé au dernier refus, par RP et API
REQ-13-13 · M05 Changement de droits	Appliquer les retraits de droits et réévaluer les autorisations obsolètes	Retirer un rôle fictif, rejouer avec session et jeton existants
REQ-13-14 · M06 Contrôle côté serveur	Appliquer les autorisations à chaque requête protégée côté ressource	Accès direct API, changement d'identifiant
REQ-13-15 · M06 Administration et séparation	Comptes individuels, rôles limités, approbation des opérations sensibles	Création, élévation et exécution avec rôles insuffisants

Intégration et sessions

Exigence	Comportement attendu	Vérification
REQ-13-16 · M07 Fédération selon protocole	Lier la transaction et vérifier émetteur, audience, signature, état, nonce et redirect ; invalide : refus	Jeu positif et négatif ; Code + PKCE S256
REQ-13-17 · M07 Contournement et en-têtes	Accès directs fermés ; seules les identités attestées par des composants de confiance sont acceptées	Chemins directs, API, en-têtes falsifiés
REQ-13-18 · M08 Session locale	Session contrôlée côté serveur, cookies protégés, identifiant renouvelé à l'authentification	Fixation, expiration, rejeu, CSRF
REQ-13-19 · M08 Déconnexion précise	Invalider la session courante ; ne pas annoncer une fin globale non confirmée	Rejeu de cookie, vérification IdP, autres RP et API
REQ-13-20 · M08 Fraîcheur pour action sensible	Réauthentification forte et fraîche ; ne pas confondre rafraîchissement silencieux et nouvelle preuve	Assertion ancienne, absence de preuve
REQ-13-21 · M08 Panne et action sensible	État indisponible : refuser l'action sensible avec une indication utilisable ; MFA jamais désactivée globalement	Couper l'état en laboratoire
REQ-13-36 · M08 Protection des jetons	Jetons liés à la bonne audience, conservés côté serveur ; mauvaise audience : refus	Jeton d'une autre audience

Journaux, données, continuité et expérience

Exigence	Comportement attendu	Vérification
REQ-13-22/23 · M09 Journal d'audit	Journaliser acteur, événement, cible, horodatage, résultat, sans secret ; accès aux journaux restreint	Événements fictifs, perte de collecte
REQ-13-35 · M09 Incident et notification	Qualifier l'incident et notifier selon les règles applicables, sans délai inventé	Scénario d'incident
REQ-13-24/25 · M10 Traitement, droits et minimisation	Finalités, rôles et transferts qualifiés avant toute donnée réelle ; collecte minimale ; canal pour les droits des personnes	Revue documentaire
REQ-13-26/27 · M11 Sauvegardes et restauration	Copies chiffrées et isolées ; réconciliation des retraits, facteurs et sessions avant remise en service	Restauration en environnement isolé

Exigence	Comportement attendu	Vérification
REQ-13-28/29 · M11 Support et objectifs de service	Opérateur et suppléant désignés ; SLI, SLO et RTO/RPO définis avant service réel	Revue de l'organisation de support
REQ-13-34 · M11 Maintenance et chaîne logicielle	Veille des dépendances, correctifs et revue des avis de sécurité	Contrôles CI, audit de dépendances
REQ-13-30/31 · M12 Accessibilité et équipements partagés	Parcours en français, aide humaine, méthodes accessibles sans abaisser les contrôles ; aucune information résiduelle sur poste partagé	Clavier, lecteur d'écran, appareils partagés
REQ-13-32/33 · M13 Sortie, portabilité et coûts	Export sous mandat, réenrôlement des facteurs non transférables ; coût complet suivi	Exercice de sortie, bilan TCO

6. Outils techniques

6.1 Technologies retenues

Couche	Technologie	Rôle et pertinence
Identité	Keycloak 26.x (conteneur officiel)	Fournisseur d'identité open source mature : OIDC, WebAuthn, sessions, journal ; évite de réimplémenter les fonctions critiques
Données	PostgreSQL 18.x	Moteur relationnel éprouvé ; bases logiquement séparées, accès minimaux, sauvegarde et restauration testées
Serveur / fédération	Node.js 24 LTS, TypeScript, Express 5, openid-client 6	BFF confidentiel : OIDC Code + PKCE S256, jetons conservés côté serveur
Interface	React 19, Vite	Interface en français, serveur d'authentification distinct de l'application
Infrastructure	Debian supportée, conteneurs OCI, Docker Compose, Nginx, HTTPS	Déploiement simple, reproductible et sécurisé
Tests et chaîne	Vitest, Playwright, tests d'intégration réels	Vérification automatisée des exigences ; dépôt privé et contrôles de livraison

Les versions indiquées sont des familles supportées ; la version corrigée et l'empreinte (digest) exactes sont fixées à l'implémentation après vérification des avis de sécurité. En particulier, l'avis Express du 28 octobre 2026 relatif à body-parser impose une version corrigée et la vérification de la dépendance réellement résolue.

6.2 Justification des choix

- **Keycloak** couvre nativement OIDC et WebAuthn et dispose d'une documentation sur les configurations supportées.
- **OIDC Code + PKCE S256** correspond aux recommandations de la RFC 9700 pour les applications web.
- **PostgreSQL** est la base de données prise en charge par Keycloak et adaptée à la sauvegarde chiffrée et à la restauration.
- **Un BFF** garde les jetons côté serveur et réduit la surface exposée au navigateur.

Si l'exploitation de Keycloak devait dépasser les capacités disponibles, l'examen d'un service d'identité géré compatible OIDC et WebAuthn serait ouvert, en tenant compte de l'export des données : les clés privées WebAuthn ne sont pas transférables et une migration impose un réenrôlement.

7. Architecture et fonctionnement général

7.1 Architecture logique

Le navigateur atteint un proxy HTTPS, puis l'interface web et son BFF, qui s'authentifient auprès de Keycloak. L'application métier valide les jetons et contrôle les droits à chaque requête. Keycloak et l'application utilisent des données logiquement séparées dans PostgreSQL. Les sauvegardes sont chiffrées et isolées ; l'administration et les secrets sont réservés aux personnes mandatées.

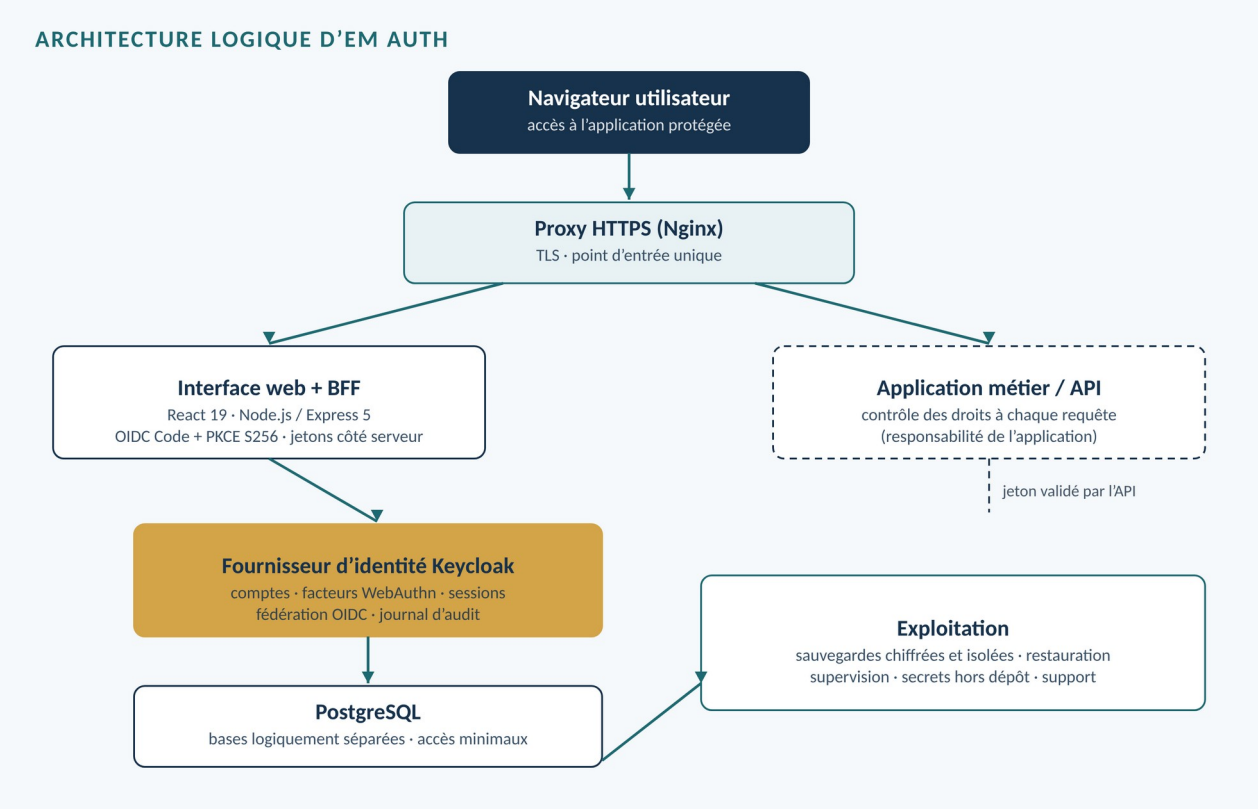


Figure 2 — Architecture logique de la plateforme

7.2 Disponibilité et évolution

Le premier déploiement repose sur une machine et une base, ce qui constitue un point unique de panne assumé pour la première tranche. La haute disponibilité et l'isolation multiclient feront l'objet d'études et de tests propres avant toute extension.

8. Méthodologie de réalisation

8.1 Démarche

La réalisation suit une démarche **test-first, par sprints de deux à trois semaines**. Avant chaque développement, des tests exécutables sont écrits et leur échec attendu est établi ; ils sont conservés après réalisation et leurs résultats documentés. Les doubles de test servent aux tests unitaires, tandis que l'authentification, l'intégration, la navigation et la restauration sont éprouvées sur les composants réels.

Étape	Pratique retenue
Conception	Contraintes, menaces, critères et modèle de données ; maquettes des parcours
Développement	Services testés, versions de dépendances figées, secrets hors dépôt, revue de code
Test	Tests unitaires, d'intégration réels, scénarios de bout en bout (Playwright), tests négatifs de sécurité
Sécurité	Modélisation des menaces, contrôles CI, audit des dépendances, revue indépendante des points critiques
Exploitation	Supervision, sauvegarde, restauration et exercices de reprise avant tout service réel
Preuves	Chaque résultat consigne version, environnement, préconditions, résultat, écart et décision ; aucun test n'est affaibli pour obtenir un succès

8.2 Qualité, sécurité et fiabilité

- Les 36 exigences sont rattachées à un scénario de test précis et suivies dans un registre de traçabilité.
- Les états de mesure distinguent succès, échec et **inconnu** : une cible non observée n'est jamais comptée comme réussie.
- Les jeux de données de test sont fictifs ; aucune donnée réelle n'est traitée avant qualification des finalités, des rôles et des transferts.

9. Sécurité, données et conformité

9.1 Menaces prises en compte

Le projet traite notamment le phishing et l'interception AiTM, le vol de session, la fraude à l'enrôlement ou à la récupération, le contournement des applications, les privilèges excessifs, la fuite de secrets, le déni de service, la perte de sauvegarde et les vulnérabilités de la chaîne logicielle. Les protections sont interdépendantes : un succès de connexion ne prouve pas leur efficacité.

9.2 Protection des données et cadre béninois

Finalités, catégories nécessaires, durée de conservation, accès, lieux, responsables et sous-traitants sont définis avant tout traitement de données réelles, avec un canal pour les droits des personnes. Le Code du numérique béninois et ses modifications sont analysés dans leur version applicable. Les référentiels NIST, OAuth et WCAG servent d'appui technique et ne constituent pas une certification.

10. Planning d'exécution

10.1 Phases de réalisation

Le planning comprend **12 sprints (S01 à S12) de deux à trois semaines**, soit environ **24 à 36 semaines** hors attentes longues, pour un effort estimé d'environ 286 heures de travail. Ces estimations sont indicatives et exprimées en durée relative, sans date officielle.

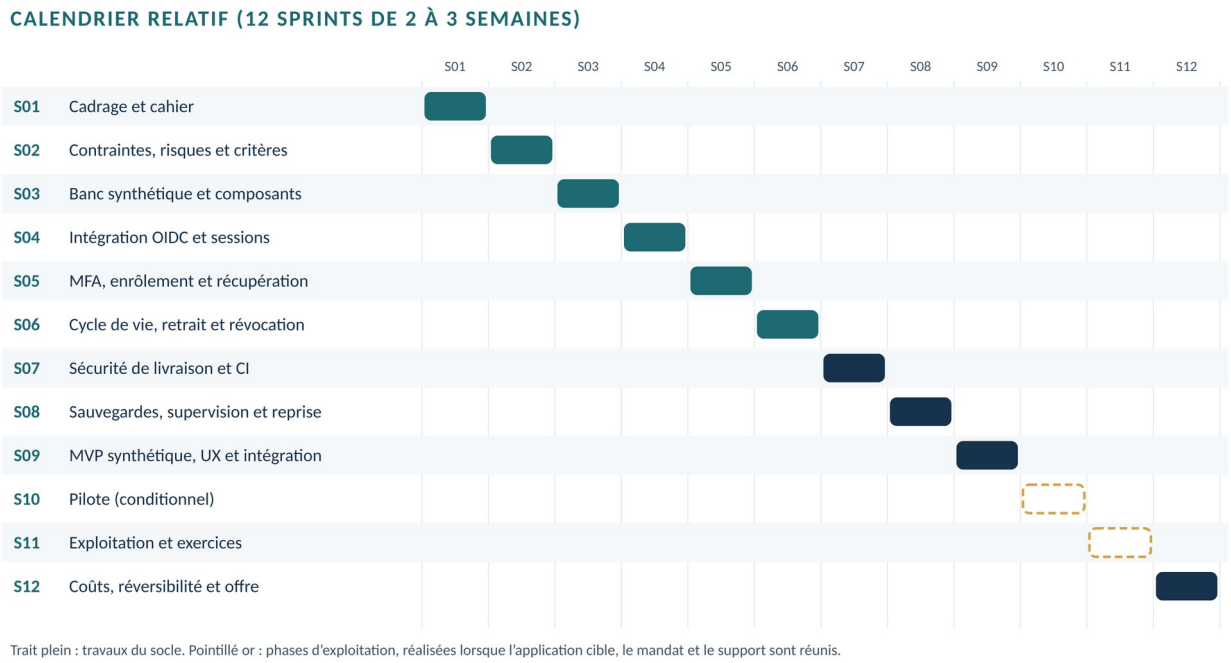


Figure 3 — Calendrier relatif d'exécution (12 sprints)

Sprint	Travaux	Livrable principal
S01	Cadrage et cahier des charges	Cahier des charges de référence
S02	Contraintes, risques et critères	Dossier de critères et de risques
S03	Banc synthétique et composants	Environnement de test reproductible
S04	Intégration OIDC et sessions	Intégration OIDC testée
S05	MFA, enrôlement et récupération	Parcours d'enrôlement et de récupération
S06	Cycle de vie, retrait et révocation	Retrait mesuré par cible
S07	Sécurité de livraison et contrôles CI	Pipeline avec contrôles de sécurité
S08	Sauvegardes, supervision et reprise	Restauration éprouvée
S09	MVP synthétique, UX et intégration	MVP sur données fictives
S10	Pilote, après réunion des conditions (application, mandat, support)	Bilan de pilote
S11	Exploitation et exercices	Dossier d'exploitation
S12	Coûts, réversibilité et offre	Bilan chiffré et dossier d'offre

10.2 Ressources et coûts

Les travaux de S01 à S06 s'appuient sur des ressources locales déjà disponibles et sur des données fictives, sans nouvelle dépense prévue. À partir de S07, l'hébergement, le stockage, la sauvegarde, la messagerie, la supervision, le domaine, la forge, le support, la sécurité et les aspects juridiques font l'objet de devis. Le coût total de possession (TCO) est suivi sur l'ensemble des postes, y compris l'énergie, la connectivité, le support et la sortie.

10.3 Livrables

- Plateforme EM AUTH fonctionnelle et intégrée à une application cible.
- Dossier d'intégration (périmètre, inventaire des chemins, protocole, limites).
- Rapports de tests (scénarios, versions, preuves, résultats et écarts).
- Dossier d'exploitation (support, supervision, sauvegarde, restauration, incidents, réversibilité).
- Bilan de pilote et dossier d'offre.

11. Critères de réussite et d'évaluation

Les critères ci-dessous découlent des objectifs et des recherches menées. Les cibles sont **prévisionnelles** : elles seront confirmées ou ajustées par les résultats mesurés pendant les tests.

11.1 Conformité fonctionnelle et tests

Indicateur	Méthode de mesure	Cible prévisionnelle
Exigences vérifiées	Registre de traçabilité REQ ↔ scénarios T13	36 exigences avec test exécuté et résultat consigné
Tests négatifs critiques	Scénarios de contournement, rejeu, faux domaine, invitation rejouée	0 échec critique non traité
Intégration OIDC	Jeu de tests positifs/négatifs (émetteur, audience, signature, état, nonce, redirect)	100 % des cas négatifs refusés
Accès directs	Essais depuis un réseau non fiable	Aucun accès direct non maîtrisé

11.2 Sécurité et fiabilité des mécanismes d'authentification

Indicateur	Méthode de mesure	Cible prévisionnelle
Privilèges protégés par MFA résistante au phishing	Part des comptes privilégiés disposant du facteur requis	100 % avant tout pilote
Retrait effectif	Temps entre l'ordre autorisé et le dernier refus observé, par application et API	Nouvelle connexion refusée immédiatement ; refus sur chaque cible dans le délai convenu pour la cible (cible non observée = inconnu)
Récupération sensible	Scénarios avec preuve insuffisante ou même approbateur	100 % refusés
Journaux	Inspection des journaux et des rapports	Aucun secret, jeton ou code

11.3 Performance, disponibilité et reprise

Indicateur	Méthode de mesure	Cible prévisionnelle
Connexion	Taux de parcours aboutis / tentatives admissibles, échecs ventilés	Seuil à fixer après les premières mesures sur le banc

Indicateur	Méthode de mesure	Cible prévisionnelle
Restauration	Restauration d'une sauvegarde en environnement isolé, réconciliation des retraits	Restauration réussie et délais mesurés, sans réactivation implicite
RTO / RPO	Mesures lors des exercices de reprise	Objectifs définis par fonction avant service réel
Panne	Coupure de l'état en laboratoire	Action sensible refusée, MFA jamais désactivée

11.4 Utilisabilité, accessibilité et coûts

Indicateur	Méthode de mesure	Cible prévisionnelle
Accessibilité	Tests clavier, lecteur d'écran et appareils autorisés	Parcours critiques conformes aux principes WCAG 2.2 (dont 3.3.8)
Enrôlement	Personnes éligibles ayant le facteur requis / personnes éligibles	Privilégiés séparés des utilisateurs ordinaires
Support et coûts	Heures de support et coût complet sur période	Suivi complet, comparaison à périmètre équivalent
Incidents	Événements qualifiés et limites de collecte	Zéro enregistré ne vaut pas zéro incident

Plusieurs seuils (fraîcheur, expiration, délais de retrait, SLO, RTO/RPO, conservation, capacité) sont volontairement liés aux premières mesures du banc ; ils seront fixés à ce moment, sur la base de résultats observés.

12. Conclusion

EM AUTH répond au besoin de sécuriser l'accès aux applications critiques d'une organisation en s'appuyant sur des mécanismes éprouvés : authentification résistante au phishing, fédération OIDC, récupération contrôlée, retrait mesuré des accès et exploitation vérifiable.

Les objectifs sont de qualifier, enrôler, authentifier, récupérer, retirer et exploiter de façon maîtrisée, avec une expérience accessible en français et un coût complet suivi. La solution associe Keycloak, PostgreSQL, un BFF Node.js/TypeScript et une interface React, selon une démarche test-first en douze sprints d'environ 24 à 36 semaines.

Les résultats attendus sont une plateforme intégrée à une application, 36 exigences vérifiées par des scénarios exécutés, des sauvegardes restaurées, un dossier d'exploitation et un bilan chiffré. Ce cahier des charges constitue la référence de travail pour ces étapes.

Annexe A — Glossaire

Terme	Définition
MFA	Authentification reposant sur plusieurs facteurs distincts

Terme	Définition
WebAuthn / passkey	Authentification à clé publique liée au service, pouvant résister au phishing
OIDC / IdP	OpenID Connect : protocole de fédération ; IdP : fournisseur d'identité
PKCE	Mécanisme liant le code d'autorisation au client qui l'a demandé
BFF	Serveur intermédiaire d'interface, qui conserve et contrôle les échanges sensibles
RP	Application utilisatrice du fournisseur d'identité (relying party)
RTO / RPO	Délai de reprise visé / perte maximale de données admissible
SLO / SLA	Objectif de service / engagement de service contractuel
MVP / TCO	Tranche minimale viable / coût total de possession

Annexe B — Références

Les versions, prix et textes juridiques évoluent ; ils sont revalidés à l'implémentation.

- NIST SP 800-63B-4 — page du NIST : lignes directrices sur l'authentification
- RFC 9700 — texte de la RFC : recommandations de sécurité OAuth 2.0
- Keycloak — documentation officielle : configurations supportées
- PostgreSQL — page officielle : cycle de versions
- Express — avis officiel : avis de sécurité body-parser du 28 octobre 2026
- W3C — WCAG 2.2 : accessibilité du contenu web
- SGG Bénin — portail : recherche du Code du numérique